



HR Security Pack

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S items: HR1 (personnel screening), HR2 (security awareness training), HR3 (offboarding / access revocation) **Related:** A7 (access review/revocation), A10 (device standard), child-safety obligations **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This pack defines the human-side security controls for Lumi Reading: who is screened before they can touch student data, what security awareness training everyone completes, and how access is removed when someone leaves or a role ends.

Scope: every person with any access to Lumi student data or the systems that hold it — today that is the single director; on engagement, any contractor, adviser, or support person. The three sections map one-to-one to ST4S HR1/HR2/HR3 and share one driving artefact — the **Access Register** ([ACCESS_REGISTER_TEMPLATE.md](#)) — which is the authoritative list of who has access to what and therefore what must be screened, trained, and revoked.

Truthfulness note. This pack states the **standard** and the records required to evidence it. It does **not** assert that a specific check, a specific training completion, or a specific revocation has occurred — those are Nic's real-world actions and become evidence only once done and dated (see §5). No check reference numbers, personal identifiers, or other PII appear in this document or in git; only the *outcome* (e.g. "current WWCC held — verified") is recorded in the evidence pack, with the underlying detail kept in a restricted HR file.

2. Section A — Employment / engagement screening standard (HR1)

2.1 Standard

Before **any** person is given access to Lumi student data (the app data, the [lumi-ninc-au](#) production project, the portals, or the support/admin mailboxes), they must hold:

- a **current Working With Children Check (WWCC)** valid for the relevant jurisdiction (Lumi operates with Australian schools; the WWCC is the primary, mandatory screening for anyone who can access children's data); and
- **optionally, a National Police Check (NPC)** where warranted by the role or requested by a partner school as an additional assurance.

The check must be **verified as current** — sighted and confirmed against the issuing authority, not merely asserted — before access is granted, and re-verified on expiry.

2.2 What is recorded, and where

Field	Stored where
Check type (WWCC / NPC)	Restricted HR file (not git)
Reference / card number	Restricted HR file only — never git, never this pack
Issue date, expiry date	Restricted HR file (expiry drives re-verification)
Outcome ("current — verified", verifier, date verified)	Evidence pack (this is the only field surfaced for ST4S)

The evidence pack contains only the outcome line. The underlying document, card number, and personal details are held in a restricted HR file (e.g. password manager / encrypted store), consistent with data-minimisation and with §5 of the device standard (no PII in the repo).

2.3 Cadence

- **Before access:** no student-data access is granted until a current WWCC is verified (this is a hard gate in onboarding, §4).
- **On expiry:** the expiry date in the restricted HR file drives re-verification; a lapsed check means access is suspended until renewed.
- **Annual reconciliation:** at the annual access review, confirm every person in the Access Register still holds a current check.

3. Section B — Security awareness training program (HR2)

3.1 Standard

Everyone with access completes **security awareness training at least annually** (and at onboarding, before or immediately on being granted access). Training covers the ST4S content areas:

1. **Phishing & social engineering** — recognising and reporting suspicious email/SMS/calls; that Lumi will never ask for a password/OTP; verifying unexpected requests out of band.
2. **Passwords & MFA** — the Lumi credential standard (14+ / complexity, per A2), a password manager, unique passwords per system, and mandatory MFA on privileged accounts (per [ACCESS_CONTROL_POLICY.md](#) §6).
3. **Data handling & classification** — what counts as student PII, minimisation, Australian data-residency ([lumi-ninc-au](#), [australia-southeast1](#)), and not moving student data out of approved systems.
4. **Incident reporting** — how and when to raise a suspected incident, and the response path ([EV9_INCIDENT_RESPONSE_PLAN.md](#)); report early, don't sit on it.
5. **Device security** — the endpoint standard ([DEVICE_STANDARD.md](#)): lock screen, encryption, updates, no shared accounts, lost-device response.
6. **Privacy & child-safety obligations** — child-safety duty of care, WWCC obligations, the privacy policy and APP obligations, and appropriate handling of children's information.
7. **Acceptable use** — approved-systems-only, no credentials in code/tickets, no shadow tools handling student data, and the branch→PR→review workflow as a security control (peer review before merge).

3.2 Delivery and records

- Training may be delivered via a reputable external module (e.g. a security awareness provider) and/or an internal walkthrough of the ST4S content areas above and these policies.
- **Completion is recorded and dated:** name, date completed, module/version, and topics covered. The dated completion record is the HR2 evidence.
- New joiners complete it at onboarding (§4); everyone re-completes annually.

3.3 Records template

Person (named)	Role	Module / content version	Date completed	Next due	Evidence (certificate / attestation ref)
Nic (Director)	Director / all access	ST4S content areas 1–7 + policy walkthrough	2026-...-...	+12 months	(certificate / signed attestation)

4. Section C — Offboarding / access-revocation checklist (HR3)

4.1 Standard

When a person leaves, a role ends, or a device/engagement is terminated, **all system access is revoked same-day** — and **immediately** where the departure is involuntary or there is any suspicion of malicious intent. Revocation is driven by that person's row(s) in the **Access Register** so nothing is missed.

4.2 Trigger and timing

Situation	Timing
Planned departure / engagement end	Same business day as the last day
Involuntary / for-cause / suspected malicious	Immediately — before or at notification; treat as a potential incident (EV9_INCIDENT_RESPONSE_PLAN.md)
Role change (reduced scope)	Same-day downgrade to least privilege for the new role

4.3 Checklist (run against the leaver's Access Register rows)

For each system the person appears against in the Access Register, revoke and record the date/time:

- ☐ **Identity / SSO** — disable the Google/Workspace or primary identity; end active sessions.
- ☐ **GCP / Firebase** ([lumi-ninc-au](#)) — remove all IAM role bindings; confirm no lingering service-account impersonation or key access.
- ☐ **GitHub** — remove from the org/repo; revoke personal access tokens, SSH keys, and any OIDC/CI trust tied to the person.
- ☐ **Apple Developer** — remove from the team; revoke signing access.
- ☐ **Google Play Console** — remove user and permissions.
- ☐ **Portals** — remove/disable super-admin ([/superAdmins/{uid}](#)) and any school-admin/teacher membership; per [ACCESS_CONTROL_POLICY.md](#) §3.3 and the server-op offboarding path, this revokes app-level access too.

- ☐ **Support / admin mailboxes** — remove delegated access to support/admin/demo/review mailboxes; reset shared-mailbox credentials if the person knew them.
- ☐ **Domain registrar & DNS** — remove account access; rotate credentials if shared.
- ☐ **Cloudflare** (status worker / edge) — remove account access; rotate API tokens the person held.
- ☐ **Password manager** — revoke vault access; **rotate every shared secret** the person could have seen (this is the critical step for a for-cause exit).
- ☐ **Devices** — collect or remotely wipe any Lumi device (`DEVICE_STANDARD.md` §5); retire the device-register row.
- ☐ **Access Register** — mark every row revoked with date/time and who performed it; the register is the completed evidence.

4.4 Verification

After revocation, confirm the person can no longer authenticate to any system (spot-check the highest-risk: GCP/Firebase, GitHub, super-admin portal), and that every shared secret they could have known has been rotated. Record the verification date. A for-cause exit additionally runs the incident-response review to check for any action taken before revocation.

5. Supporting evidence index

Control	Evidence (owned by Nic)
Screening standard (HR1)	Restricted HR file (type/ref/date/expiry) + outcome line in the evidence pack ("current WWCC verified", verifier, date)
Awareness training (HR2)	Dated completion record / certificate per person (§3.3)
Offboarding (HR3)	Completed checklist (§4.3) with dated revocations, driven by the Access Register
Access register (driver for HR1 & HR3)	<code>ACCESS_REGISTER_TEMPLATE.md</code> (populated)
Server-side portal/app revocation	<code>ACCESS_CONTROL_POLICY.md</code> §3.3, §8 (super-admin + membership offboarding)
Device collection / wipe	<code>DEVICE_STANDARD.md</code> §5
Incident path for for-cause exits	<code>EV9_INCIDENT_RESPONSE_PLAN.md</code>

6. Known gaps / reviewer must confirm

- NIC — WWCC HELD (2026-07-24); just record the details.** Nic holds a current WWCC, so HR1 screening for the director is met in substance. Remaining step: record its type/reference/date/expiry in the **restricted HR file (not git)** and add a one-line *outcome* to the evidence pack ("current WWCC held — verified [date]"). Repeat for any contractor/adviser who later gains access to student data.
- NIC — training not yet completed.** §3 defines the program; the **dated completion record** for each person (starting with the director) must exist for HR2 to be evidenced.
- NIC — offboarding is untested until used.** The §4 checklist is real and driven by the Access Register, but there is no completed run yet (single operator). Confirm it is exercised on the first real departure, and

consider a dry-run against the register to prove no system is missed.

- **Access register dependency.** HR1 and HR3 both depend on a **populated** Access Register (`ACCESS_REGISTER_TEMPLATE.md`); that register is currently a template awaiting Nic's population and first review.
- **Restricted HR file location.** Confirm where the restricted HR file lives (password manager / encrypted store) and that it holds no PII in git.
- **Sign-off.** This pack requires Nic's sign-off, and HR1/HR2/HR3 are only ST4S-submittable once the real check, the dated training record, and the populated register exist.